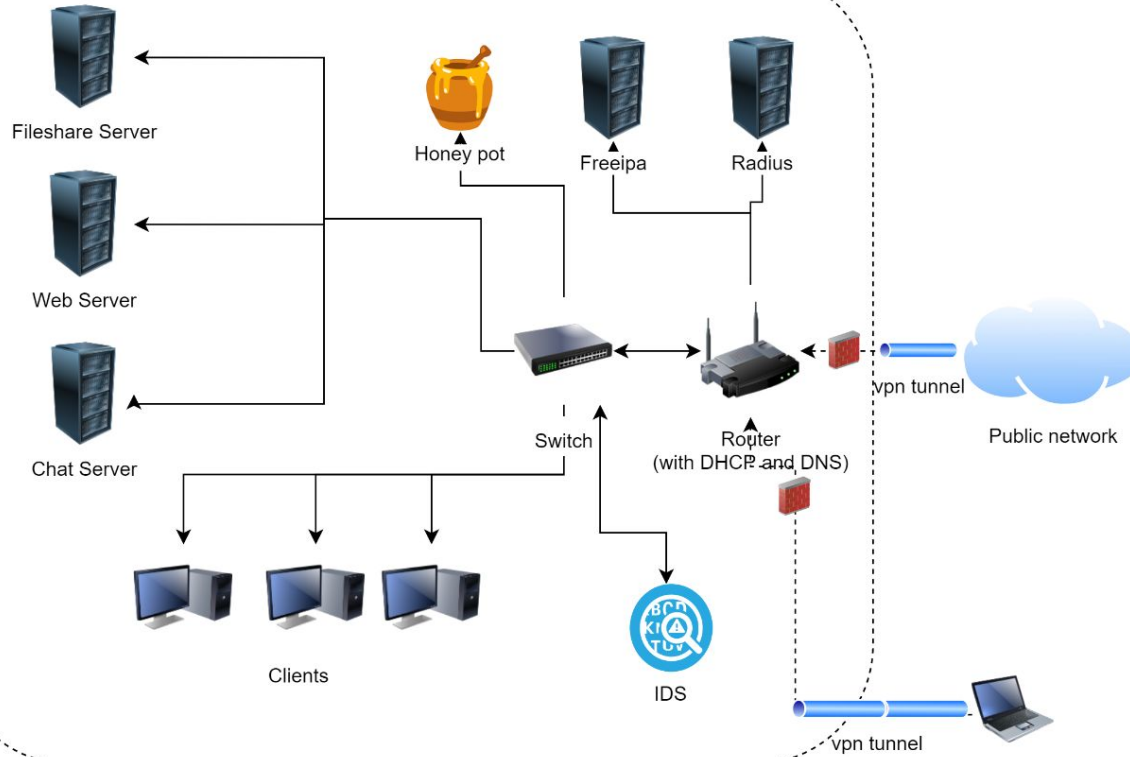


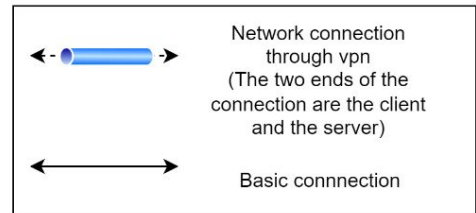
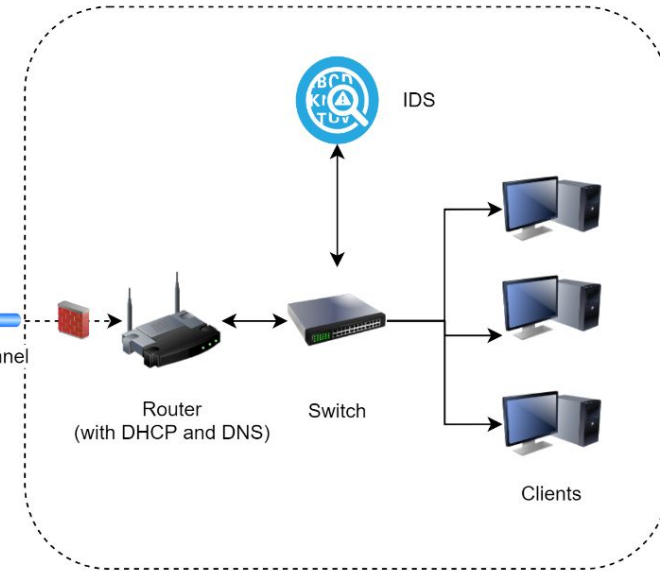


BNSS Presentation Group9

Stockholm 192.168.1.0/24



London 192.168.2.0/24



Stockholm connects London

- We use OpenVPN in tunnel mode for the two connections
- Stockholm network on 192.168.1.0/24
- London Network on 192.168.2.0/24
- Tunnel itself is on 10.8.1.0/24
- Both the networks have their own DNS, DHCP and IPS servers
- Stockholm and London Authenticate each other using certificates
- The tunnel uses AES-256 for encryption
- Traffic to 192.168.1.0/24 is forwarded to Stockholm router from the London network
- Can connect to the safe server from Stockholm and London office

Employees Outside Office connects to Stockholm

- Employees connect to Stockholm using OpenVPN Connect from outside office
- Employee's machine authenticate server using certificate
- Stockholm router uses username,password and 2FA from the employee for authentication
- The tunnel uses AES-256 for encryption
- Tunnel itself is on 10.8.0.0/24
- Can access normal services(Web Server, Chat Server)
- Can not connect to the safe server from outside office

Firewall

- Protect against DoS attack from outside using rate limiting to 10 per second
- Disable any traffic initiated from outside the network including pings
- Only connections to OpenVPN ports are allowed
- Not able to connect to the following using the VPN from outside network
 - Stockholm router
 - Super Safe server
 - FreeIPA
 - radius server

Authentication

- FreeIPA Centralized Identity Management
 - Users, groups and privileges
 - Certificate Authority
 - One-Time Password (2FA)
 - Can be used for certificate revocation as well
- FreeRADIUS Authentication Proxy
 - Wi-Fi
 - Routers send authentication requests
 - EAP-TLS
- Services query FreeIPA LDAP for client authentication

Employee to employee communication – Chat and File Sharing

- Chat Server
 - The server is called Rocket Chat
 - It is a open source slack like server
 - It is self hosted inside the network
 - Anyone outside the VPN can not access this server
- File Sharing
 - This done via ownCloud
 - Again the server is hosted inside the company network
 - Nobody outside the network can access it
 - Authentication via FreeIPA

Other Security

- Snort(IDS)
 - In combination with Splunk (SIEM) to monitor threats within the internal network.
 - Convert Snort alert logs to JSON so that Splunk can parse them.
 - Download and configure Snort community rules from the Snort community, while also writing some custom rules(see in following slides).

```
alert tcp any any -> any $HTTP_PORTS ( msg:"SQL HTTP URI blind injection attempt";  
flow:to_server,established; http_uri; content:"sleep(",fast_pattern,nocase; content:"/";  
metadata:policy balanced-ips drop,policy max-detect-ips drop,policy security-ips drop;  
service:http; classtype:web-application-attack; sid:49666; rev:2; )
```

- Hfish(Honeypot)
 - Configured the HFish honeypot and set up a node on an Ubuntu machine, configuring the decoy services(like web and ssh).
 - On the HFish server side, all attacks on the honeypots can be monitored.

One more thing

- To determine if the IDS and honeypot do work, we simulate a compromised internal machine and perform network scanning and attacks.

Let's see first from the **attacker's perspective**.

```
(root@kali)-[~]  
# nmap -T3 -F -n --min-parallelism 64 192.168.1.0/24
```

Scan the intranet first

```
Nmap scan report for 192.168.1.107  
Host is up (0.00035s latency).  
Not shown: 94 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
23/tcp    open  telnet  
53/tcp    open  domain  
80/tcp    open  http  
3306/tcp  open  mysql  
MAC Address: 00:0C:29:EB:36:DE (VMware)
```

```
(root@kali)-[/usr/share/wordlists]  
# hydra -L fasttrack.txt -P fasttrack.txt -vV ssh://192.168.1.107  
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in  
military or secret service organizations, or for illegal purposes (this is non  
-binding, these ** ignore laws and ethics anyway).
```

Using hydra for ssh password brute attack.

```
(root@kali)-[/usr/share/wordlists]  
# gobuster dir --url http://192.168.1.107/ --wordlist /usr/share/wordlists/d  
irbuster/directory-list-2.3-medium.txt
```

Using gobuster for directory brute scan.

Find a easy
target.(honey pot
decoy actually)

```
[root@web_server ~]#ls  
bin boot dev etc home lib lib64 lost+found media mnt  
[root@web_server ~]#cd home  
Command 'cd home' is not available.
```

Trapped in the honeypot!

One more thing

- To determine if the IDS and honeypot do work, we simulate a compromised internal machine and perform network scanning and attacks.

Let's see first from the blue's team perspective.

```
i Time Event
> 13/03/2025 11:51:43.000 { [-]
  action: allow
  b64_data: R0VUIC9odHRwJTNEJTJGJTJGc3dpayBIVFRQLzEuMQ==
  class: none
  dir: C2S
  dst_addr: 192.168.1.107
  dst_ap: 192.168.1.107:80
  dst_port: 80
  gid: 119
  iface: ens33
  mpis: 0
  msg: (http_inspect) URI path contains consecutive slash characters
  pkt_gen: stream_tcp
  pkt_len: 31
  pkt_num: 1237719
  priority: 3
```

```
> 13/03/2025 11:25:16.000 { [-]
  action: allow
  class: none
  dir: C2S
  dst_addr: 192.168.1.237
  dst_ap: 192.168.1.237:993
  dst_port: 993
  eth_dst: 00:0C:29:68:CB:FD
  eth_len: 60
  eth_src: 00:0C:29:BE:D3:96
  eth_type: 0x800
  gid: 122
  iface: ens33
  ip_id: 21889
  ip_len: 24
  mpis: 0
  msg: (port_scan) TCP portscan
  pkt_gen: raw
  pkt_len: 44
  pkt_num: 210089
  priority: 3
```

Attack > Scan list

Scan the IP: Node: Scanning type: By scanning ports:

Duration time:

Scan the IP	IP intelligence	Scanned node	By scanning the IP	Scanning type	Total	By scanning ports
192.168.1.10 LAN	...	Built-in Nodes	192.168.1.105	TCP	20	80(http)
192.168.1.1 LAN	...	Built-in Nodes	192.168.1.105	UDP	1	68(bootpc)
213.80.101.3 Sweden	...	Built-in Nodes	192.168.1.105	ICMPv4	1	
213.80.96.2 Sweden	...	Built-in Nodes	192.168.1.105	ICMPv4	1	
192.168.1.104 LAN	...	client002	192.168.1.107	TCP	32	80 9190 9898
192.168.1.108 LAN	...	Built-in Nodes	192.168.1.105	TCP	191	1723(pptp)

Find the attack in splunk.

Learnings from the project

- We are far from AGI, LLM models are not yet helpful we should read documentation
- If something doesn't work just restart or go home and it will work the next day
- If something works today doesn't mean will work tomorrow as well

Appendix

Stockholm router

Zones

Zone ⇒ Forwardings	Input	Output	Forward	Masquerading	
lan ⇒ wan tun tun1	accept ▼	accept ▼	accept ▼	☐	≡ Edit Delete
wan ⇒ REJECT	reject ▼	accept ▼	reject ▼	☒	≡ Edit Delete
tun ⇒ lan	accept ▼	accept ▼	accept ▼	☐	≡ Edit Delete
tun1 ⇒ lan	accept ▼	accept ▼	accept ▼	☐	≡ Edit Delete

Add

firewall

Allow-OpenVPN	Incoming <i>IPv4</i> and <i>IPv6</i> , protocol <i>UDP</i> From wan To this device , port <i>1194</i>	<i>Accept</i> input	☒	 <a>Edit <a>Delete
Allow-ClientVPN	Incoming <i>IPv4</i> and <i>IPv6</i> , protocol <i>UDP</i> From wan To this device , port <i>56001</i>	<i>Accept</i> input	☒	 <a>Edit <a>Delete
Rate Limit New Connections	Incoming <i>IPv4</i> , protocol <i>TCP</i> From wan To this device Limit matching to <i>10</i> packets per <i>second</i>	<i>Drop</i> input	☒	 <a>Edit <a>Delete
Super Safe server	Forwarded <i>IPv4</i> and <i>IPv6</i> From tun1 To lan , IP <i>192.168.1.183</i>	<i>Reject</i> forward	☒	 <a>Edit <a>Delete
Safe some internal services	Incoming <i>IPv4</i> and <i>IPv6</i> From tun1 To this device , IP <i>192.168.1.1</i> , <i>192.168.1.213</i> , <i>192.168.1.100</i>	<i>Reject</i> input	☒	 <a>Edit <a>Delete

London router

Zones

Zone ⇒ Forwards	Input	Output	Intra zone forward	Masquerading	
lan ⇒ wan tun <i>REJECT all others</i>	accept ▼	accept ▼	accept ▼	☐	≡ Edit Delete
wan ⇒ <i>REJECT</i>	reject ▼	accept ▼	reject ▼	☒	≡ Edit Delete
tun ⇒ lan <i>REJECT all others</i>	accept ▼	accept ▼	accept ▼	☒	≡ Edit Delete

Add

Save & Apply ▼ Save Reset

firewall

Allow-OpenVPN

Incoming *IPv4* and *IPv6*, protocol *UDP*

From **wan**

To **this device**, port *1194*

Accept input



Edit

Clone

Delete

allow-tunnel

Forwarded *IPv4* and *IPv6*

From **lan**

To **tun**

Accept forward



Edit

Clone

Delete

tunnel-allow

Forwarded *IPv4* and *IPv6*

From **lan**

To **tun**

Accept forward



Edit

Clone

Delete

Rate Limit New Connections

Incoming *IPv4*, protocol *TCP*

From **wan**

To **this device**

Limit matching to *10* packets per *second*

Drop input



Edit

Clone

Delete

Add

Save & Apply



Save

Reset

Radius_auth

CancelStockholm_9_2Apply

DetailsIdentityIPv4IPv6Security

Security

WPA & WPA2 Enterprise

▼

Authentication

TLS

▼

Identity

employee2

Domain

CA certificate

ca.pem

▼

CA certificate password

🔒

☐ Show passwords

☐ No CA certificate is required

User certificate

employee2.crt

▼

User certificate password

🔒

User private key

employee2.key

▼

User key password

.....

🔒

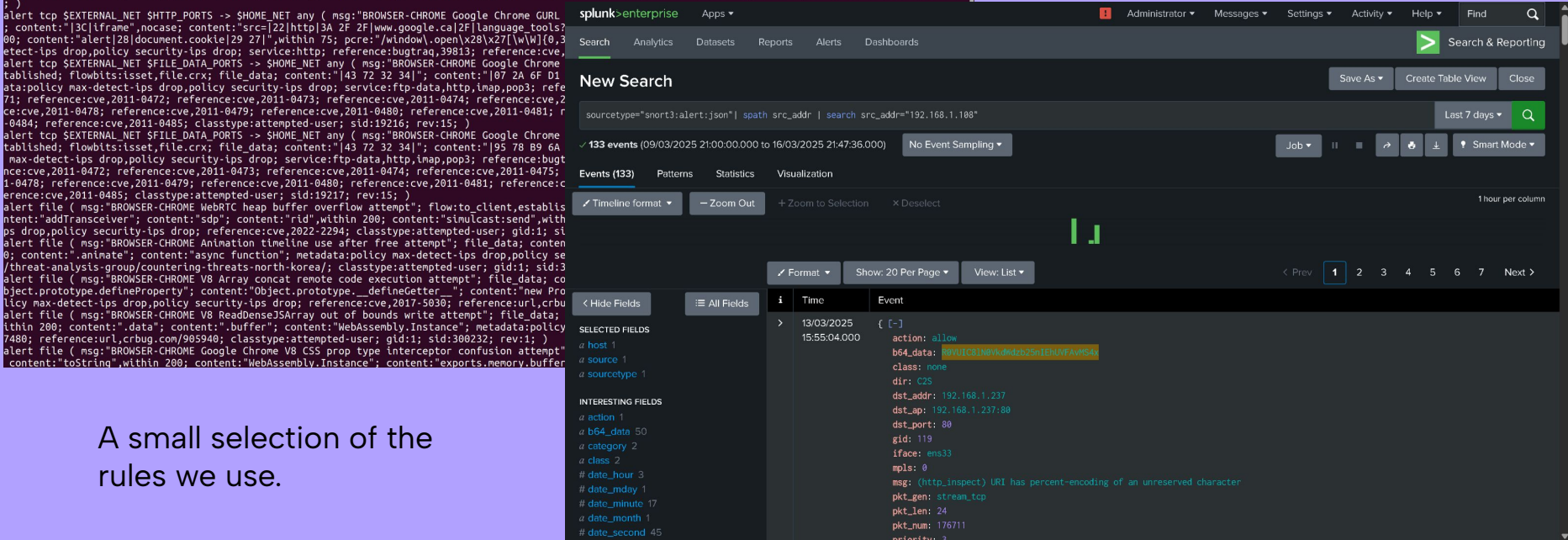
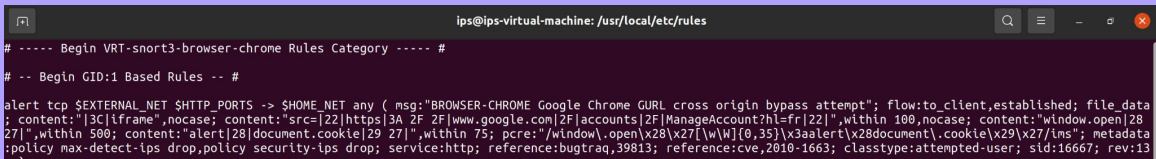
☐ Show passwords

Radius_log

```
listen {  
    type = "acct"  
    ipv6addr = ::  
    port = 0  
    limit {  
        max_connections = 16  
        lifetime = 0  
        idle_timeout = 30  
    }  
}  
listen {  
    type = "auth"  
    ipaddr = 127.0.0.1  
    port = 18120  
}  
Listening on auth address * port 1812 bound to server default  
Listening on acct address * port 1813 bound to server default  
Listening on auth address :: port 1812 bound to server default  
Listening on acct address :: port 1813 bound to server default  
Listening on auth address 127.0.0.1 port 18120 bound to server inner-tunnel  
Listening on proxy address * port 50219  
Listening on proxy address :: port 56108  
Ready to process requests
```

```
rlm_ldap (ldap): Opening additional connection (0), 1 of 32 pending slots used  
rlm_ldap (ldap): Connecting to ldap://ipa.group9.com:389  
rlm_ldap (ldap): Waiting for bind result...  
rlm_ldap (ldap): Bind successful  
(8) Sent Access-Accept Id 96 from 192.168.1.213:1812 to 192.168.1.1:36741 length  
177  
(8) MS-MPPE-Recv-Key = 0x9f5ea6b639de9f0b12e48cefc23470c945b8430881e2d358c4383  
f93702586ab  
(8) MS-MPPE-Send-Key = 0x92538fe79c58b294d9765be2b211bce649e6ed7625730d73b1a88  
211b02c1adb  
(8) EAP-Message = 0x03330004  
(8) Message-Authenticator = 0x00000000000000000000000000000000  
(8) User-Name = "employee2"  
(8) Framed-MTU += 994  
(8) Finished request  
(8) Received Access-Request Id 96 from 192.168.1.1:36741 to 192.168.1.213:1812 l  
ength 231  
(8) User-Name = "employee2"  
(8) NAS-IP-Address = 192.168.1.1  
(8) NAS-Identifier = "0c9d92ba73fc"  
(8) Called-Station-Id = "0C-9D-92-BA-73-FC:Stockholm_9_2"  
(8) NAS-Port-Type = Wireless-802.11  
(8) Service-Type = Framed-User  
(8) NAS-Port = 1  
(8) Calling-Station-Id = "70-32-17-DA-2C-F3"  
(8) Connect-Info = "CONNECT 54Mbps 802.11a"  
(8) Acct-Session-Id = "15A7B831737AABB1"  
(8) WLAN-Pairwise-Cipher = 1027076  
(8) WLAN-Group-Cipher = 1027076  
(8) WLAN-AKM-Suite = 1027073  
(8) Framed-MTU = 1400  
(8) EAP-Message = 0x023300060d00  
(8) State = 0x49cbfead4ef8f35efbb3fc3fffd9b6898  
(8) Message-Authenticator = 0x892e4309d4f055172f9745d29c2a20bd  
(8) Restoring &session-state  
(8) &session-state:Framed-MTU = 994  
(8) &session-state:TLS-Session-Information = "(TLS) TLS - recv TLS 1.3 Handsha  
ke ClientHello"
```

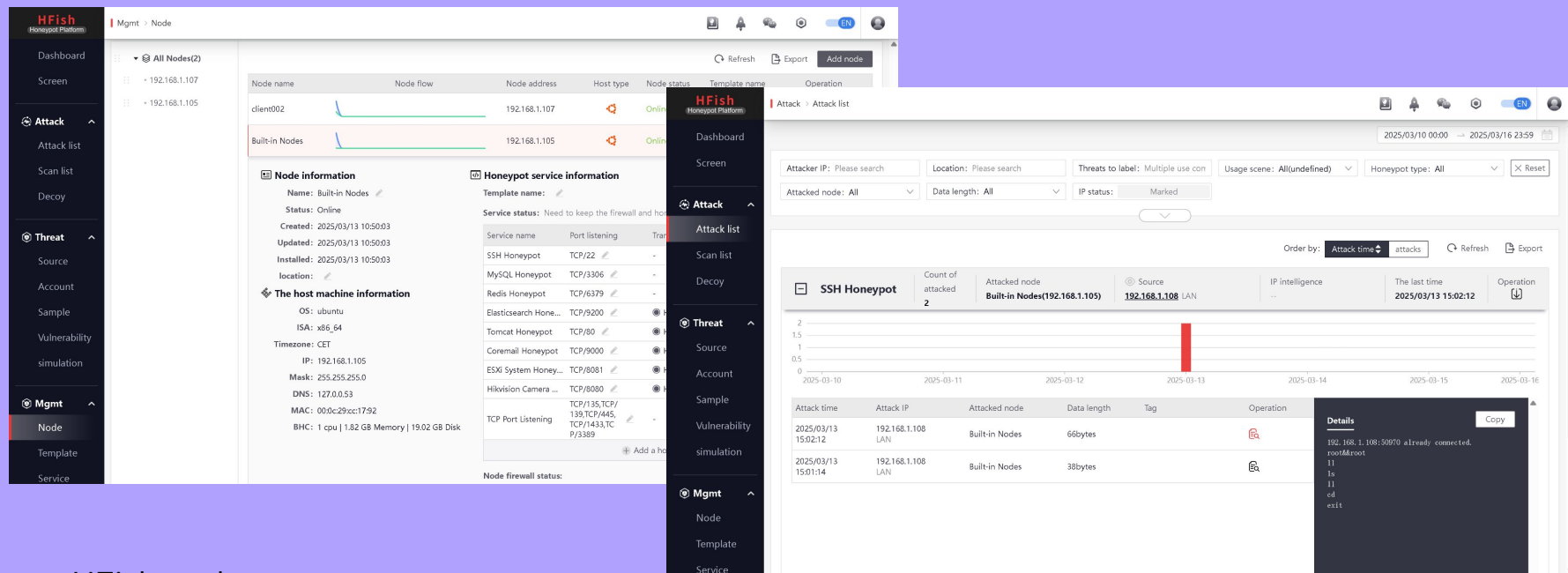
Snort3+splunk



A small selection of the rules we use.

Using splunk with snort for attack alert.

Hfish



Hfish node management

Hfish attack report